

Kashi · Contrato de la API REST

Proyecto Final G108 · Hito 1 · Tamara Rivera

Datos generales

Concepto	Valor
URL base (local)	http://localhost:3000/api
Formato	JSON (Content-Type: application/json)
Autenticación	JWT en la cabecera Authorization: Bearer <token>
Moneda	Pesos chilenos (CLP), números enteros sin decimales
Formato de error	`{ "message": "Descripción del error" }`

Accesos

Nivel	Requisito
Público	Ninguno
Cliente	Token válido (cualquier rol)
Admin	Token válido + rol: "admin"

Códigos de estado

Código	Significado	Cuándo
200	OK	Consulta, edición o eliminación exitosa

201	Created	Registro, producto o pedido creado
400	Bad Request	Faltan datos o tienen formato inválido
401	Unauthorized	Sin token, token inválido o credenciales incorrectas
403	Forbidden	Token válido, pero sin el rol necesario
404	Not Found	El recurso no existe
409	Conflict	Email ya registrado o producto con pedidos asociados
500	Server Error	Error inesperado del servidor

Auth

POST /api/auth/register · Público. Registra un usuario nuevo. Siempre se crea con rol cliente.

Envía:

```
{ "nombre": "Tamara Rivera", "email": "tamara@correo.cl", "password": "MiClave123" }
```

Responde 201:

```
{ "id": "6f1c2a9e-3b4d-4c8a-9e21-7a5b3c1d2e4f", "nombre": "Tamara Rivera", "email":
"tamara@correo.cl", "rol": "cliente" }
```

Errores: 400 faltan campos · 409 el email ya está registrado

POST /api/auth/login · Público. Valida las credenciales y devuelve un token JWT.

Envía:

```
{ "email": "tamara@correo.cl", "password": "MiClave123" }
```

Responde 200:

```
{ "token": "eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...", "usuario": { "id": "6f1c2a9e-
3b4d-4c8a-9e21-7a5b3c1d2e4f", "nombre": "Tamara Rivera", "email": "tamara@correo.cl",
"rol": "cliente" } }
```

Errores: 400 faltan campos · 401 email o contraseña incorrectos

GET /api/auth/me · Cliente. Devuelve los datos del usuario dueño del token (vista Mi perfil).

Headers: Authorization: Bearer <token>

Responde 200:

```
{ "id": "6f1c2a9e-3b4d-4c8a-9e21-7a5b3c1d2e4f", "nombre": "Tamara Rivera", "email": "tamara@correo.cl", "rol": "cliente", "created_at": "2026-10-30T22:15:00.000Z" }
```

Errores: 401 token ausente o inválido

Categorías

GET /api/categorias · Público. Lista las categorías (filtro de la Galería y formulario de producto).

Responde 200:

```
[ { "id": "b2e8...", "nombre": "Mochi" }, { "id": "c4f1...", "nombre": "Dorayaki" }, { "id": "d7a3...", "nombre": "Daifuku" }, { "id": "e9b5...", "nombre": "Té y matcha" }, { "id": "f1c6...", "nombre": "Cajas de regalo" } ]
```

Productos

GET /api/productos · Público. Lista los productos. Filtros opcionales por query string.

Query param	Ejemplo	Uso
categoria	?categoria=Mochi	Filtro de la Galería
destacado	?destacado=true	Carrusel del Home

Responde 200:

```
[ { "id": "a3f9c2e1-5d7b-4e2a-8c1f-9b6d4e3a2c10", "nombre": "Mochi de matcha", "descripcion": "Masa de arroz glutinoso rellena de crema de matcha.", "precio": 2500, "imagen_url": "https://images.unsplash.com/mochi-matcha.jpg", "stock": 30, "destacado": true, "categoria": { "id": "b2e8...", "nombre": "Mochi" } } ]
```

GET /api/productos/:id · Público. Detalle de un producto (vista Detalle).

Responde 200: el mismo objeto de producto de arriba.

Errores: 404 producto no encontrado

POST /api/productos · Admin. Crea un producto (formulario del panel admin).

Headers: Authorization: Bearer <token de admin>

Envía:

```
{ "nombre": "Dorayaki de matcha", "descripcion": "Dorayaki relleno de anko y crema de matcha.", "precio": 3300, "imagen_url": "https://images.unsplash.com/dorayaki-matcha.jpg", "stock": 20, "destacado": false, "categoria_id": "c4f1..." }
```

Responde 201: el producto creado, con su id y su categoria.

Errores: 400 faltan campos o precio/stock inválidos · 401 sin token · 403 no es admin

PUT /api/productos/:id · Admin. Edita un producto. Se envía el objeto completo (mismo formato que el POST).

Headers: Authorization: Bearer <token de admin>.

Responde 200: el producto actualizado.

Errores: 400 datos inválidos · 401 · 403 · 404 producto no encontrado

DELETE /api/productos/:id · Admin. Elimina un producto.

Headers: Authorization: Bearer <token de admin>

Responde 200:

```
{ "message": "Producto eliminado correctamente" }
```

Errores: 401 · 403 · 404 producto no encontrado · 409 el producto tiene pedidos asociados (en ese caso conviene dejar su stock en 0)

Pedidos

POST /api/pedidos · Cliente. Crea un pedido con el contenido del carrito (botón "Pagar").

> **Importante:** el frontend envía solo los IDs y las cantidades. El backend busca el precio real en la base de datos, calcula el total, guarda precio_unitario en detalle_pedido y descuenta el stock.

Headers: Authorization: Bearer <token>

Envía:

```
{ "items": [ { "producto_id": "a3f9c2e1-5d7b-4e2a-8c1f-9b6d4e3a2c10", "cantidad": 2 },
{ "producto_id": "7d2b9f4a-1c3e-4a5b-9d8c-2e1f6a7b8c90", "cantidad": 1 } ] }
```

Responde 201:

```
{ "id": "9c8b7a6d-5e4f-4a3b-8c2d-1e0f9a8b7c6d", "total": 8000, "estado": "pendiente",
"created_at": "2026-10-30T23:05:00.000Z", "items": [ { "producto_id": "a3f9...",
"nombre": "Mochi de matcha", "cantidad": 2, "precio_unitario": 2500, "subtotal": 5000
}, { "producto_id": "7d2b...", "nombre": "Dorayaki clásico", "cantidad": 1,
"precio_unitario": 3000, "subtotal": 3000 } ] }
```

Errores: 400 carrito vacío, cantidad inválida o stock insuficiente · 401 sin token · 404 algún producto no existe

GET /api/pedidos/mis-pedidos · Cliente. Historial de compras del usuario dueño del token (vista Mi perfil).

Headers: Authorization: Bearer <token>.

Responde 200: arreglo de pedidos con el mismo formato del POST, del más reciente al más antiguo.

Errores: 401 sin token

GET /api/pedidos · Admin. Todos los pedidos de la tienda (vista Pedidos admin). Cada pedido incluye además usuario: `{ id, nombre, email }`.

Headers: Authorization: Bearer <token de admin>.

Responde 200: arreglo de pedidos.

Errores: 401 · 403

Resumen

Método	Ruta	Acceso	Vista que la usa
POST	/api/auth/register	Público	Registro
POST	/api/auth/login	Público	Login

GET	/api/auth/me	Cliente	Mi perfil
GET	/api/categorias	Público	Galería, Formulario producto
GET	/api/productos	Público	Home, Galería
GET	/api/productos/:id	Público	Detalle, Formulario (editar)
POST	/api/productos	Admin	Formulario producto
PUT	/api/productos/:id	Admin	Formulario producto
DELETE	/api/productos/:id	Admin	Panel admin
POST	/api/pedidos	Cliente	Carrito (Pagar)
GET	/api/pedidos/mis-pedidos	Cliente	Mi perfil
GET	/api/pedidos	Admin	Pedidos (admin)